AIS — Lab reference guide (part 2)

Key Concepts: Securing a Linux Server

Site A follow-up mission — named admin account · sudo · SSH hardening · UFW firewall · logs · ITIL ticket

Charles MADUBA — home lab, 13 October 2026

Contents

1. What this mission is about
2. Checking services: "is it running?"
3. Reachable host vs reachable service
4. Named accounts, root and sudo
5. SSH hardening
6. The UFW firewall
7. Logs: Linux and Windows
8. Change safety: snapshots and safety sessions
9. Real incidents from this lab
10. Recording the work: the ITIL ticket
11. Command cheat sheet
12. Glossary
13. Lab access: start, connect, check, stop
14. Replay: the mission step by step

1. What this mission is about

The first lab **built** the service: Active Directory, DNS, GLPI and the LDAP link between them. This mission **secures and checks** it, the way an administrator does before putting a server into production:

1 Observe → 2 Test network & DNS → 3 Named admin → 4 SSH + firewall → 5 Logs → 6 Ticket → 7 Acceptance tests

> **Analogy:** the building already exists. Now you give each caretaker their own badge (named account), lock the master key in a safe (no root over SSH), close every door except the two the public needs (firewall), check the CCTV recordings (logs) and write it all in the maintenance book (ticket).

Machine	Role	Lab address
DC01 (Serveur_TP, WIN-RG5VDD2MS10)	Windows Server 2022: AD DS, DNS, DHCP role	192.168.56.10
GLPI01 (GLPI-Site-A, glpi01)	Debian 13: Apache, MariaDB, GLPI 11	192.168.56.20 (+ NAT 10.0.3.15)

Laptop	Administration workstation: SSH, RDP, browser	192.168.56.1

2. Checking services: "is it running?"

Always **observe before you change anything**. A baseline tells you what "normal" looks like, so you can prove later that your change did not break anything.

Question	Windows (PowerShell)	Linux (Debian)
Is the service running?	`Get-Service ADWS, DNS` → Running	`systemctl status apache2` → active (running)
Is the domain alive?	`Get-ADDomain`	—
Which DNS zones exist?	`Get-DnsServerZone`	—
Network settings	`ipconfig /all`	`ip a`, `ip route`
Disk / memory	Task Manager	`df -h`, `free -h`

- **ADWS** (Active Directory Web Services) is what the PowerShell AD commands talk to. If it is stopped, `Get-ADDomain` fails even if AD itself is fine.
- **systemd** is the program that starts and supervises services on modern Linux; `systemctl` is its command. "enabled" means the service starts automatically at boot.
- A **forward zone** (`exemple.lan`) answers name → IP. A **reverse zone** (`x.x.x.in-addr.arpa`) answers IP → name. The lab has no reverse zone for 192.168.56.0/24, which is a possible improvement.

3. Reachable host vs reachable service

This is one of the most useful distinctions in troubleshooting:

Test	Proves	Lab example
`ping` (ICMP)	The **machine** answers on the network	GLPI answers ping from the AD
`Test-NetConnection IP -Port 80` / `bash -c '</dev/tcp/IP/389'`	A **service** is listening on that port	Port 80 → True; port 443 → False
`nslookup name`	The **name** resolves, and which DNS server answered	`exemple.lan` → 192.168.56.10, answered by 192.168.56.10#53

> **Port 443 lesson:** ping succeeded but port 443 failed. The machine is up; only the HTTPS service is missing, because GLPI was never configured with a certificate. So port 443 was deliberately **not** opened in the firewall: opening a port that nothing uses only widens the attack surface.

Why the AD's DNS is essential for GLPI: the zone `exemple.lan` exists only on the AD's DNS. With an internet DNS server, GLPI could not find the domain controller, so LDAP and every AD login would fail.

4. Named accounts, root and sudo

	Working as root	Named account + sudo
Who did it?	Logs only say "root"	Logs show **admin-sitea**: traceability
Mistakes	Every command has full power	Full power only for commands prefixed with `sudo`
Passwords	Everybody shares the root password	Each admin types **their own** password
Leaving staff	Change root password everywhere	Disable one account

- **sudo** = "superuser do": run *one* command with root's rights. On Debian, members of the group `sudo` may use it.
- `adduser admin-sitea` creates the user, home folder and password (interactive: run it alone, not pasted with other commands).
- `usermod -aG sudo admin-sitea`: `-a` = append. Without `-a`, `-G` would **replace** all the user's groups.
- Proof: `id admin-sitea` shows `27(sudo)`; `sudo whoami` prints `root`.
- Prompt reminder: `$` = normal user, `#` = root.

5. SSH hardening

SSH (Secure Shell, port 22) is the encrypted remote command line. The server program is `sshd`, configured in `/etc/ssh/sshd_config`.

`PermitRootLogin` value	Meaning
`yes`	root may log in with a password: dangerous (brute-force target)
`prohibit-password` (old name `without-password`)	Debian default: root only with an SSH key
`no`	root can never log in over SSH. Admins use a named account, then sudo

The safe procedure (the order matters)

1. Snapshot the VM, and keep a **second SSH session open** (existing sessions survive an SSH restart).
2. Read the active value: `sudo sshd -T | grep -i permitrootlogin` (`-T` = print the real, effective config).
3. Edit: `sudo nano +33 /etc/ssh/sshd_config` or `sudo sed -i 's/^#PermitRootLogin prohibit-password/PermitRootLogin no/' /etc/ssh/sshd_config`.
4. **Test the syntax before restarting**: `sudo sshd -t` (lowercase t). A broken file + restart = nobody can connect.
5. Apply: `sudo systemctl restart ssh`; check again with `sshd -T`.
6. Prove it from a **new** window: `ssh root@…` → Permission denied; `ssh admin-sitea@…` → works.

Lines starting with `#` in a config file are comments: they are ignored and the built-in default applies.

6. The UFW firewall

UFW (Uncomplicated Firewall) is a simple front end to the Linux kernel firewall (netfilter / iptables / nftables). Principle: **deny everything coming in by default, then open only what is needed.**

Rule	Why
`ufw default deny incoming`	Nothing gets in unless explicitly allowed
`ufw default allow outgoing`	The server can still start connections: LDAP to the AD (389), DNS (53), updates
`ufw allow 22/tcp`	SSH administration. **Add it before** `ufw enable` or you lock yourself out
`ufw allow 80/tcp`	GLPI web interface (HTTP)
443 not opened	No HTTPS service exists yet

- **Stateful firewall:** replies to a connection the server started itself (e.g. the AD answering GLPI's LDAP query) are let back in automatically. That is why LDAP still works with "deny incoming".
- `ufw show added` lists rules *before* enabling; `ufw status verbose` shows the active policy and rules (IPv4 and "(v6)").
- `ss -tulpn` lists listening ports with the program name. In the lab MariaDB listens on **127.0.0.1:3306** only, so the database is not reachable from the network even without a firewall rule. Defence in depth: two layers protecting it.
- **Always test after enabling**: open GLPI in the browser and a new SSH session, while the old session is still open.
- Possible improvement: `ufw allow from 192.168.56.0/24 to any port 22 proto tcp` to allow SSH only from the admin network.

7. Logs: Linux and Windows

Linux: the systemd journal

```
sudo journalctl -u ssh --since "1 hour ago" --no-pager | tail -n 12
sudo journalctl -u apache2 --since today --no-pager
sudo journalctl -u mariadb --since today --no-pager
sudo tail -n 5 /var/log/apache2/access.log
```

Log line	Meaning
`Accepted password for admin-sitea from 192.168.56.1`	Successful named login, with source IP
`Failed password for root from 192.168.56.1`	Root attempt refused: the hardening works
`Started apache2.service` / `mariadbd: ready for connections`	Services started at boot
`-- Boot …`	Marks a system restart in the journal

Windows: Event Viewer from PowerShell

```
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4624} -MaxEvents 8 |
  Format-Table TimeCreated, Id, @{n='Compte';e={$_.Properties[5].Value}}, @{n='IP';e=
{$_.Properties[18].Value}}
Get-WinEvent -LogName System -MaxEvents 5
Get-WinEvent -LogName 'DNS Server' -MaxEvents 3 | Format-List TimeCreated, Id, Message
```

Event ID	Log	Meaning
4624	Security	Successful logon (account + source IP)
4625	Security	Failed logon: watch for many in a row (brute force)
7036	System	A service started or stopped
1059	System (DHCP Server)	DHCP could not check its authorisation in AD (AD not ready yet at boot)
2 / 4	DNS Server	DNS server started / zones loaded

Accounts ending in `$` (e.g. `WIN-RG5VDD2MS10$`) are computer accounts. `::1` is IPv6 for "this same machine".

8. Change safety: snapshots and safety sessions

- **Snapshot before every risky change** (`VBoxManage snapshot "VM" take "name"`). A snapshot of a running VM also saves its memory, so a restored VM shows "Saved" and resumes.
- **Safety session:** keep one admin session open and untouched while changing SSH or the firewall; test from a new window.
- **Validate before applying:** `sshd -t`, `ufw show added`.
- **Interactive commands** (`adduser`, `passwd`, `nano`, `ufw enable`) are run one at a time.
- **Never interrupt a package installation** (Ctrl+C) unless it is truly dead; if it was interrupted, repair with `sudo dpkg --configure -a`.
- Shut down cleanly: `sudo poweroff` (Linux), `Stop-Computer` (Windows), especially for a domain controller.

9. Real incidents from this lab

Symptom	Diagnosis	Fix / lesson
`apt install ufw` stuck at 96 % (`man-db` trigger), SSH "Connection reset", VirtualBox "Guru Meditation"	Host PC out of memory (12 GB for 2 VMs + RDP + browser; "Committed" near the limit). Guru Meditation = fatal VM crash	Power off, restore snapshot `avant-SSH-UFW`, free host memory, redo the change. Skip the slow step: `echo "man-db man-db/auto-update boolean false" | sudo debconf-set-selections`
GLPI: "Unable to connect to the LDAP directory" right after enabling UFW	Bottom-up: `ping 192.168.56.10` → Destination Host Unreachable; port 389 unreachable; VirtualBox: Serveur_TP Powered Off	Not the firewall. Start the DC, retest ping + port 389, then log in as it01. Don't blame the last change without evidence

`startvm`: "already locked by a session"	The VM was already running	Check with `VBoxManage list runningvms`
Snapshot error "Could not find a registered machine named 'Serveur_TP'"	The VM name has a trailing space	Use the exact name: `"Serveur_TP "`

Troubleshooting order (unchanged from part 1): network → IP → DNS → service/port → authentication (LDAP) → application (GLPI).

10. Recording the work: the ITIL ticket

- **Demande (request)** vs **Incident**: planned improvement work is a request (or a change); an incident means a service is broken or degraded.
- **ITIL categories** can be nested ("Comme enfant de"): `Sécurité > Administration serveur`.
- **Urgency × Impact → Priority** (Moyenne × Moyen → Moyenne).
- Link the **asset** (GLPI01) so the server's history shows the intervention.
- A good **solution** lists: actions, services concerned, continuity tests, result, and **no secrets**.
- Lifecycle: En cours (Attribué) → **Résolu** (solution given) → **Clos** (solution approved).
- Login source matters: the local `glpi` Super-Admin uses **Base interne GLPI**; imported AD users use **AD-Site-A**. Default GLPI accounts (`glpi`, `tech`, `normal`, `post-only`) should have their passwords changed or be disabled.
- GLPI shows times in UTC unless time zones are enabled.

11. Command cheat sheet

Debian (as admin-sitea)

```
which sudo || apt install -y sudo              # (as root) make sure sudo exists
sudo adduser admin-sitea                       # create a named account (interactive)
sudo usermod -aG sudo admin-sitea              # give it sudo rights
id admin-sitea ; groups admin-sitea            # check groups
sudo whoami                                    # → root
sudo sshd -T | grep -i permitrootlogin         # effective SSH setting
sudo sshd -t && echo "Syntaxe OK"              # test sshd_config
sudo systemctl restart ssh
sudo ufw default deny incoming ; sudo ufw default allow outgoing
sudo ufw allow 22/tcp ; sudo ufw allow 80/tcp
sudo ufw show added ; sudo ufw enable ; sudo ufw status verbose
sudo ss -tulpn                                 # listening ports
ping -c 3 192.168.56.10
timeout 3 bash -c '</dev/tcp/192.168.56.10/389' && echo OPEN || echo CLOSED
sudo journalctl -u ssh --since "1 hour ago" --no-pager
sudo poweroff
```

Windows Server

```
Get-Service ADWS, DNS, DHCPServer
Get-ADDomain
Get-DnsServerZone | Format-Table ZoneName, ZoneType, IsReverseLookupZone
Test-NetConnection 192.168.56.20 -Port 80
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4624} -MaxEvents 8
Stop-Computer
```

VirtualBox host

```
.\VBoxManage.exe list runningvms
.\VBoxManage.exe startvm "GLPI-Site-A" --type headless
.\VBoxManage.exe snapshot "GLPI-Site-A" take "avant-SSH-UFW"
```

12. Glossary

Term	Meaning
ADWS	Active Directory Web Services: the service PowerShell's AD commands rely on
Attack surface	Everything an attacker could try to reach: open ports, accounts, services
Defence in depth	Several independent protection layers (e.g. MariaDB on localhost *and* a firewall)
DHCP	Dynamic Host Configuration Protocol: hands out IP settings automatically
DNSSEC	DNS Security Extensions: digital signing of DNS zones
Event ID	Number identifying a Windows event type (4624, 4625, 7036…)
Guru Meditation	VirtualBox's name for a fatal virtual machine crash
HTTP / HTTPS	Web protocol, port 80 / encrypted with TLS, port 443
ICMP	Internet Control Message Protocol, used by `ping`
journald / journalctl	systemd's central log and the command to read it
Least privilege	Each account gets only the rights it needs
Named account (compte nominatif)	An account tied to one real person, for traceability
NetBIOS name	Short legacy domain name (EXEMPLE), as in `EXEMPLE\Administrateur`
Port	Numbered door for a service: 22 SSH, 53 DNS, 80 HTTP, 389 LDAP, 443 HTTPS, 3306 MariaDB, 3389 RDP
RDP	Remote Desktop Protocol (Windows remote desktop, port 3389)
Snapshot	Restore point of a VM (disk, and memory if it was running)
SSH / sshd	Secure Shell / the SSH server program
Stateful firewall	A firewall that remembers connections and lets their replies back in
sudo	"Superuser do": run one command with root's rights

systemd / systemctl	Linux service manager / its command
TCP / UDP	Connection-oriented / connectionless transport protocols
UFW	Uncomplicated Firewall, front end to the Linux kernel firewall
UTC	Coordinated Universal Time (Paris = UTC+2 in summer)

13. Lab access: start, connect, check, stop

Everything runs on the laptop in VirtualBox. No password is written in this guide: you type each one at its prompt.

VM name in VirtualBox	Role	Address	How you connect	Account
`Serveur_TP` **(the name ends with a space)**	DC01 — Windows Server 2022, AD DS, DNS	192.168.56.10	Remote desktop: `mstsc /v:192.168.56.10`	`EXEMPLE\Administrateur`
`GLPI-Site-A`	GLPI01 — Debian 13, Apache, MariaDB, GLPI 11	192.168.56.20	SSH from PowerShell: `ssh admin-sitea@192.168.56.20`	`admin-sitea` + `sudo` (since the mission). Before the mission: `stagiaire` then `su -`. Root over SSH is refused.
GLPI web interface	Help desk and inventory	`http://192.168.56.20/` (server root, not /glpi)	Browser on the laptop	`glpi` with source **Base interne GLPI**; `it01`, `employe01`, `direction01` with source **AD-Site-A**

> **Before you start:** the laptop has about 12 GB of RAM, so run only these two VMs. Close `Vm Proxmox`, `debian-tp` and any other VM, plus heavy browser tabs. Never run `debian-tp` at the same time: GLPI-Site-A is its clone (same GLPI database).

1 — Start the lab (domain controller first)

```
cd "C:\Program Files\Oracle\VirtualBox"
.\VBoxManage.exe list runningvms                          # what is already running?
.\VBoxManage.exe startvm "Serveur_TP " --type headless    # DC first (note the space)
#  wait 2-3 minutes: AD and DNS must be up before GLPI looks for them
.\VBoxManage.exe startvm "GLPI-Site-A" --type headless
```

`--type headless` starts the VM without a window (saves memory). Use the normal VirtualBox window instead if you want to watch it boot. "already locked by a session" just means the VM is already running.

2 — Connect

```
mstsc /v:192.168.56.10                # Windows: remote desktop to the DC
ssh admin-sitea@192.168.56.20         # PowerShell: shell on GLPI (accept the key the first
time)
start http://192.168.56.20/           # browser: GLPI
```

> Use remote desktop **or** the VirtualBox console for the DC, never both with the same account (one session per user: the second one kicks the first out).

3 — Health check in 2 minutes (bottom-up)

Check	Where	Command	Expected
Network	Laptop	`ping 192.168.56.10` / `ping 192.168.56.20`	Replies
GLPI web port	Laptop	`Test-NetConnection 192.168.56.20 -Port 80`	TcpTestSucceeded : True
AD alive	DC (PowerShell)	`Get-Service ADWS, DNS` · `Get-ADDomain`	Running · domain exemple.lan
GLPI services	GLPI	`systemctl status apache2 mariadb --no-pager`	active (running)
DNS from GLPI	GLPI	`nslookup exemple.lan`	192.168.56.10, answered by 192.168.56.10
LDAP port from GLPI	GLPI	`timeout 3 bash -c '</dev/tcp/192.168.56.10/389' && echo OPEN`	OPEN
End to end	Browser	Log in as `it01`, source AD-Site-A	GLPI technician interface

If a check fails, stop there and fix that layer first: network → IP → DNS → service/port → LDAP → GLPI.

4 — Snapshots (restore points)

```
.\VBoxManage.exe snapshot "GLPI-Site-A" list
.\VBoxManage.exe snapshot "Serveur_TP " list
.\VBoxManage.exe snapshot "GLPI-Site-A" take "avant-xxx"      # before any change
.\VBoxManage.exe snapshot "GLPI-Site-A" restore "avant-xxx"   # VM must be powered off
```

Known restore points: Serveur_TP `INV-avant-recolement-2026-10-06`, `avant-nettoyage-dns-2026-10-06`; GLPI-Site-A `clone-initial-2026-10-06`, `avant-SSH-UFW`. Run `list` to see all of them.

5 — Stop the lab cleanly (GLPI first, DC last)

```
sudo poweroff                    # on GLPI (SSH session)
Stop-Computer                    # on the DC (remote desktop PowerShell)
.\VBoxManage.exe list runningvms # nothing left = done
```

Pulling the plug on a domain controller can corrupt the AD database: always shut it down from inside.

14. Replay: the mission step by step

Prerequisite: the lab from part 1 is running and healthy (health check in the previous section). Keep **one SSH session open and untouched** during steps 4–5; test from a second window.

Step	Do	Prove
1 Observe	DC: `Get-Service ADWS, DNS, DHCPServer`, `Get-ADDomain`, `Get-DnsServerZone`. GLPI: `hostnamectl`, `ip a`, `ip route`, `df -h`, `free -h`, `systemctl status apache2 mariadb --no-pager`.	Services running, disk and memory OK
2 Network & DNS	GLPI → DC: `ping -c 3 192.168.56.10`, `nslookup exemple.lan`. DC → GLPI: `ping 192.168.56.20`, `Test-NetConnection 192.168.56.20 -Port 80` (True) and `-Port 443` (False: no HTTPS).	Both directions OK; 443 closed explained
3 Named admin	As root: `which sudo || apt install -y sudo`; `adduser admin-sitea` (run it alone, interactive); `usermod -aG sudo admin-sitea`. Log in as admin-sitea.	`id admin-sitea` shows sudo; `sudo whoami` → root
4 SSH	Snapshot `avant-SSH-UFW`. `sudo sshd -T | grep -i permitrootlogin` → set `PermitRootLogin no` in `/etc/ssh/sshd_config` → `sudo sshd -t` → `sudo systemctl restart ssh` → `sshd -T` again.	New window: `ssh root@192.168.56.20` refused, `ssh admin-sitea@…` accepted
5 Firewall	Free host RAM first. `sudo apt install -y ufw` (if stuck on man-db: see incidents). `sudo ufw default deny incoming`, `sudo ufw default allow outgoing`, `sudo ufw allow 22/tcp`, `sudo ufw allow 80/tcp`, `sudo ufw show added`, `sudo ufw enable`.	`sudo ufw status verbose`; `sudo ss -tulpn` (MariaDB on 127.0.0.1 only); GLPI web + new SSH still work; it01 LDAP login still works
6 Logs	`sudo journalctl -u ssh --since "1 hour ago" --no-pager` (find the refused root attempt), same for apache2 and mariadb. DC: `Get-WinEvent` Security 4624, System, DNS Server.	Log lines with your own test visible
7 Ticket + acceptance	GLPI: category Sécurité › Administration serveur; request "Sécurisation de l'accès d'administration...", assigned to it01, item GLPI01 linked, solution written (no secrets) → Solved → Closed. Rerun every check.	Closed ticket; acceptance table all OK

> **Oral tip:** for each step, say *why* (traceability, attack surface, least privilege) and *how you proved it* (the test from a second window, the log line, the closed ticket).

Companion to the French mission report in `mission-securisation/rapport/`. Real lab values; no passwords recorded.